

Security Audit — VaultKeepR Browser Extension

Audited version: 1.8.5 (dist/ and dist-firefox/ builds dated 2026-09-08) | Targets: Chrome (Manifest V3) + Firefox (MV3, gecko 128+) | Scope: apps/extension/ | Date: 2026-09-09 | Method: tool-assisted static audit + manual code review

8.7 / 10

Overall grade: A-

Verdict after the 2026-09-09 fixes (v1.8.5 rebuilt): no critical or high vulnerabilities; P2/P3 findings fixed and re-verified. Initial score before fixes: 8.1/10 (B+).

Fixes applied on 2026-09-09 (v1.8.5 rebuilt)

Finding	Fix	Post-build verification
F-01 (P2) CSP	Removed the bare <code>https:</code> token from <code>connect-src</code> (Chrome + Firefox); strict allowlist of first-party endpoints + public IPFS gateways; the <code>manifest-csp.test.ts</code> golden test is now hardened to reject bare <code>https:</code> / <code>http:</code> tokens (the old test only checked the <code>https://*</code> literal and let the flaw slip through)	Token absent from both dist CSPs; linter OK
F-02 (P3) Demo premium	<code>NODE_ENV === "production"</code> guard added to <code>IS_DEMO_URL</code> / <code>IS_DEMO_PREMIUM</code> in <code>useChromeSession.ts</code> (aligned with <code>DemoContext</code>)	<code>get("demo")</code> eliminated at build time (DCE) — premium write unreachable in production
F-03 (P3) Dependencies	<code>crypto-browserify</code> + <code>stream-browserify</code> moved to <code>devDependencies</code> (build-time shims only); <code>elliptic</code> ^6.6.1 override at the root	<code>browserify-sign</code> absent from production bundles; prod audit: elliptic no-fix advisory only (accepted)
F-04 (P3) host_permissions	<code>https://*/</code> removed (content scripts are already global, <code>executeScript</code> is covered by <code>activeTab</code> , DNR = block rules)	Slimmed manifests; linter OK
F-05 (P3) Hugging Face	<code>*.huggingface.co</code> / <code>*.hf.co</code> removed from <code>host_permissions</code> and CSP; <code>env.remoteHost</code> forced to <code>app.vaultkeepr.xyz</code> ; the TOS model was already self-hosted (the HF <code>remoteHost</code> was an unused <code>transformers.js</code> default)	Zero HF egress references in the bundles
Custom IPFS gateway	User setting removed (feature incompatible with the strict allowlist); resolution code removed from <code>vault-sync.js</code> , UI disabled with an explanatory note (i18n fr/en), tests updated	<code>vaultKeeperIpfsGateway</code> absent from <code>background.js</code> ; 1,868/1,868 tests green

1. Methodology and tooling

Tool	Purpose	Result
<code>addons-linter</code> (official Mozilla, latest version)	Manifest + bundle linting against AMO rules	Firefox: 0 errors, 16 warnings. Chrome: 2 errors (CWS false positives, see F-15), 21 warnings
<code>npm audit</code>	Dependency CVEs (full workspace tree)	0 critical, 0 high, 2 moderate (dev-only), 4 low
Manual egress scan	Extraction of every literal host across the 9 production bundles	No unknown host, no telemetry (see section 4)
Manual secrets scan	AWS/GitHub/Slack/PEM/mnemonic patterns	False positives only (see F-09bis)
Manual code review	Manifests, messaging, storage, WebAuthn, phishing, demo, logger redaction	See findings
<code>vitest</code> test suite	Functional regression at audit time	128 files, 1,868 tests, 0 failures (after the 2026-09-09 fixes)

2. Detailed score by category

Category	Weight	Score /10	Rationale
Manifest & permissions	15 %	7.5	<code>https://*/</code> and HF hosts removed; surface reduced to first-party endpoints; global content scripts still required for universal autofill
CSP & code injection	10 %	8.5	Strict <code>connect-src</code> allowlist (bare <code>https:</code> token removed, golden test hardened); <code>wasm-unsafe-eval</code> required (ONNX); <code>style-src unsafe-inline</code> remaining
Network & egress	15 %	9.0	Egress limited to own domains + breach check (k-anonymity); HF eliminated; zero telemetry; custom gateway removed
Storage & crypto	20 %	9.0	Secret key stored as encrypted envelope (local) + raw in <code>storage.session</code> (memory only); migration refuses to return plaintext; clipboard auto-clear
Messaging & code hygiene	15 %	9.0	Strict sender validation on sensitive operations, SSO origin allowlist with one-shot challenge, correctly gated WebAuthn bridge
Dependencies & linters	15 %	8.5	0 high/critical runtime CVEs; shims moved to devDeps; elliptic 6.6.1 (no-fix advisory accepted, absent from bundles); AMO linter 0 errors
Privacy & compliance	10 %	9.5	Phishing config inlined (zero runtime fetch), SLM model 100% self-hosted, no third-party CDN left; leakcheck email disclosed to the user
Weighted total	100 %	8.7	A- — Initially 8.1 (B+) before the 2026-09-09 fixes

3. Findings

F-01 P2 CSP: connect-src https: allows all HTTPS from extension pages FIXED 09/09

Target	Chrome + Firefox
Evidence	manifest.json:45 and manifest.firefox.json:40 — connect-src 'self' https: https://app.vaultkeepr.xyz ...
Impact	The https: token accepts any HTTPS URL. The explicit allowlist that followed was inoperative: XSS in the popup or background could exfiltrate data to any HTTPS server without violating the CSP.
Recommendation	APPLIED — token removed, explicit allowlist only (app/ipfs.vaultkeepr.xyz, pwnedpasswords, leakcheck, HIBP, IPFS gateways, etherscan/base RPC). Golden test hardened to reject bare scheme tokens.

F-02 P3 Local premium bypass via popup.html?demo=premium FIXED 09/09

Target	Chrome + Firefox
Evidence	popup-src/src/hooks/useChromeSession.ts:20–34 — IS_DEMO_URL / IS_DEMO_PREMIUM tested the URL parameter without a NODE_ENV guard. The effect (l.178-191) then wrote vaultKeeperPremiumUntil_guest (+365 days) and vaultkeeper_demo_mode to chrome.storage.local and displayed the demo vault.
Impact	Local premium entitlement activatable by a user opening the popup URL with the parameter. Commercial impact (end user on their own profile), not an external security risk: a web page cannot open this URL (no web_accessible_resources).
Fix applied	NODE_ENV guard added (matching DemoContext.tsx:24–36); dead-code elimination removes the branch from production builds.

F-03 P3 Dead dependencies and low CVE on elliptic via crypto-browserify FIXED 09/09

Target	Dependency chain (no shipped code)
Evidence	package.json (apps/extension): crypto-browserify ^3.12.0 , stream-browserify ^3.0.0 .No import of these modules in background-src/ , popup-src/ , content-src/ . Production bundle grep: browserify-sign absent, elliptic not shipped (the secp256k1 occurrences come from @noble/curves; the "elliptic" occurrences in zxcvbn dictionaries are dictionary words).
Impact	npm audit reported elliptic <6.6.1 (low, risky crypto implementation) via browserify-sign/create-ecdh — present in node_modules but not in the artifact. Zero user risk; confusion and audit noise only.
Fix applied	Both shims moved to devDependencies; elliptic ^6.6.1 override at the root. Remaining: the elliptic advisory has no upstream fix (affects all versions) — accepted risk, absent from production bundles.

F-04 P3 Maximum host permissions: https://*/* and optional all-URL http(s) FIXED 09/09

Target	Chrome + Firefox
Evidence	host_permissions contained https://*/*; optional_host_permissions contained https://*/* and http://*/*; content scripts on https://*/* + http://*/* , all_frames, match_about_blank.
Fix applied	https://*/* removed: content scripts are declared globally (no host permissions needed), chrome.scripting.executeScript on the active tab is covered by activeTab (user gesture), and the only DNR rules are of type block (host permissions not required). Remaining host permissions limited to first-party + breach-check endpoints. CWS/AMO listing should document the autofill justification.

F-05 P3 SLM model weights downloaded from the Hugging Face CDN (user IP exposure) FIXED 09/09

Target	Chrome + Firefox (offscreen/on-device inference)
Evidence	CSP allowed *.huggingface.co / *.hf.co ; @huggingface/transformers 3.8.1 in dependencies; remoteHost: "https://huggingface.co/" constant in the bundle (library default).
Root cause analysis	The TOS model is already self-hosted at https://app.vaultkeepr.xyz/models/tos-risk (slm-onnx.ts:19): no actual HF download ever occurred. The HF hosts in the manifests were vestigial.
Fix applied	HF entries removed from host_permissions and CSP in both manifests; env.remoteHost forced to app.vaultkeepr.xyz as defense in depth.

F-06 P4 style-src 'unsafe-inline' in the extension pages CSP

Evidence	manifest.json:45 , manifest.firefox.json:40 . Inline style allowed — minor style-injection surface in extension pages (no scripts).
Recommendation	Remove if the extracted CSS (assets/popup-*.css) covers 100% of React styles.

F-07 P4 wasm-unsafe-eval + Function constructor (Emscripten / ONNX Runtime)

Evidence	2 DANGEROUS_EVAL hits: dist/ort/ort-wasm-simd-threaded.jsep.mjs:80 (Function("return this") , standard Emscripten globalThis fallback) and dist/offscreen.js:2826 (same pattern). No application-level eval() , no remote code loading.
Assessment	Standard, self-contained WASM runtime pattern; no remote code execution. wasm-unsafe-eval required for ONNX inference.
Recommendation	Document as an accepted exception in docs/THREAT_MODEL.md.

F-08 P4 Breach scan: full email sent to leakcheck.io (consented and disclosed)

Evidence	packages/core/src/emailBreach.ts:40 (LEAKCHECK_URL); BreachScannerPanel.tsx:434–435 explicitly discloses the email transmission to the third party before the action. pwnedPassword.ts uses the k-anonymity range API (only the first 5 hex chars of the SHA-1).
Assessment	Compliant with the Firefox data_collection_permissions declaration (optional: PII) — never automatic, always user-triggered and informed.

F-09 P4 Linter false positives: innerHTML x9 = React DOM + @mozilla/readability

Evidence	The 9 UNSAFE_VAR_ASSIGNMENT hits map to: dangerouslySetInnerHTML in the React production runtime (content.js, background.js, vendor) and page.innerHTML = pageCacheHtml in @mozilla/readability (offscreen.js, background.js). No user-data flow into innerHTML identified.
----------	---

F-10 P4 Demo data shipped in production bundles

Evidence	DEMO_ENTRIES compiled into dist/assets/popup-popup-*.js : fake passwords, test bank card, BIP39 "abandon...about" test-vector mnemonic, SSH note. Gated (see F-02, now dead in production) but still present in the artifact.
Recommendation	Strip demo fixtures from production builds (they also serve marketing screenshots: keep a dedicated build).

F-11 INFO Confirmed strengths (manual review)

Area	Verified
Secret key at rest	Encrypted envelope in chrome.storage.local (storage.js:385,451,468); raw key only in storage.session (memory, purged on browser exit); legacy migration refuses to return plaintext if re-encryption fails (storage.js:381-386)
Sensitive messages	GET_DECRYPTED_SECRET_KEY and GET_CACHED_PASSWORD rejected when sender.tab is present or sender.id !== chrome.runtime.id (messaging.js:1356-1358, 1642-1644) — neither web pages nor other extensions can call them
onMessageExternal (SSO)	Strict origin allowlist (app.vaultkeepr.xyz, vaultkeepr.xyz) + exact type + one-shot challenge stored in session and deleted after use + type validation on id/k (messaging.js:538-598). Only {id} is sent to the cap-verify endpoint
WebAuthn MAIN world bridge	event.source === window + channel + direction + type whitelist (webauthn-content.ts:382-403); rpId validated against origin (l.412-419)
Phishing	Config inlined at build (dist/phishing-config.json 2.8 MB identical to data/, loaded via chrome.runtime.getURL , phishing.js:88) + embedded fallback lists. Zero runtime fetch — complies with the anti-IP-exposure spec
Logger	redactAddress/redactCid/redactSecret in use (redact.js); no password/mnemonic/secret in clear in log calls; debug-page-inject.js stripped from production dist (build.js:235-240)
Telemetry	No analytics/telemetry/sentry-ingest endpoint in any of the 9 bundles; no hardcoded API keys (the etherscan myapikey strings are viem defaults)
Clipboard	Copied values auto-cleared via SCHEDULE_CLIPBOARD_CLEAR with local fallback (popup bundle)
AMO	0 addons-linter errors on dist-firefox; update_url stripped for AMO (build.js:247); data_collection_permissions declared (required: none)

F-15 INFO Chrome addons-linter errors = CWS false positives

Detail	The 2 Chrome errors (BACKGROUND_SERVICE_WORKER_NOFALLBACK, ADDON_ID_REQUIRED) are Firefox requirements: for CWS, service_worker without scripts is the correct MV3 pattern and the ID is store-generated. The Firefox dist provides the background.scripts fallback + browser_specific_settings.gecko.id : both targets comply with their respective stores. offscreen/favicon warnings = Chrome-only APIs correctly absent from the Firefox manifest; chrome.offscreen calls are guarded by typeof chrome.offscreen !== "undefined" (slm-background.ts:9-11) with the slm-fallback.js fallback declared as a Firefox background script.
--------	--

F-09bis INFO Secrets scan: false positives

Detail	AKIAIOSFODNN7EXAMPLE = canonical AWS documentation example in a test; 4 "AKIA..." in automerger_wasm.b64 = random base64 collisions (not in key=secret format); mnemonic = demo fixture (see F-10).
--------	---

4. Complete network surface (egress)

Destination	Purpose	Data
app.vaultkeepr.xyz (+ /api/relay/bundler, /models/tos-risk)	Encrypted sync, SSO CAP verify, IPFS relay, TOS SLM model	E2E-encrypted blob, SSO id only, model weights
ipfs.vaultkeepr.xyz, ipfs.io, dweb.link	IPFS gateways	Encrypted CIDs
api.pwnedpasswords.com	Password breach check	First 5 hex chars of the SHA-1 (k-anonymity)
leakcheck.io	Email breach scan (user-triggered)	Full email (disclosed in the UI)
haveibeenpwned.com/api/v3/breaches	Public breach catalog	No personal data
*.huggingface.co, *.hf.co	Removed (09/09) — no actual fetch: TOS model self-hosted, remoteHost forced to app.vaultkeepr.xyz	
api.etherscan.io, mainnet.base.org	On-chain wallet reads	Public addresses

No other active egress host identified in the bundles. Remaining URLs (tailwindcss.com, rfc-editor, eprint.iacr.org, stackexchange, 4byte.sourcify.dev, react.dev) are documentation literals embedded in viem/abitype/libs — no runtime fetch. localhost = dev only.

5. Chrome / Firefox comparison

Aspect	Chrome 1.8.5	Firefox 1.8.5
Background	MV3 service worker (offscreen available)	Background scripts + slm-fallback.js
Target-specific permissions	+ offscreen, + favicon	Absent (unsupported) — code is guarded
Debug MAIN world inject	Stripped from production builds (build.js:235)	Not declared
externally_connectable	Web origins app.vaultkeepr.xyz + vaultkeepr.xyz	By extension ID (gecko id)

addons-linter	2 "errors" = Firefox requirements (CWS false positives)	0 errors
data_collection_permissions	n/a (separate CWS data disclosure)	required: none, optional PII declared
CVEs / egress / crypto	Identical (same application code, same logical bundles)	

6. Prioritized action plan

#	Action	Priority	Effort	Status
1	F-01: CSP connect-src — remove the https: token, explicit allowlist	P2	S	Done 09/09
2	F-02: NODE_ENV guard on IS_DEMO_URL/IS_DEMO_PREMIUM (useChromeSession.ts)	P3	S	Done 09/09
3	F-03: crypto-browserify/stream-browserify to devDeps + elliptic 6.6.1 override	P3	S	Done 09/09
4	F-05: remove HF from manifests + first-party env.remoteHost	P3	S	Done 09/09
5	F-04: https://*/ removed; document remaining host_permissions for CWS/AMO	P3	S	Done 09/09
6	F-06/F-10: unsafe-inline styles + strip demo fixtures from production builds	P4	S	Remaining

Report generated locally (no data transmitted) — 2026-09-09. Raw artifacts: reports/extensions/addons-linter-chrome.json, addons-linter-firefox.json, npm-audit-extension.json.
VaultKeepR 1.8.5 — Chrome + Firefox extension audit. Overall score: 8.7/10 (A-) after the 2026-09-09 fixes — initially 8.1/10 (B+). Test suite: 1,868/1,868 passing (0 failures).